

NARRATIVA EXPLICATIVA: EL ARTE IRÓNICO, LITERARIO Y PROPOSITIVO DE LA ENCUESTA DE CIBERSEGURIDAD

Reflexión Estratégica sobre Evaluación de Madurez Organizacional

Enero 2026

INTRODUCCIÓN: LA PARADOJA DE LO OBVIO

Vivimos en una época peculiar. Las organizaciones invierten millones en cortafuegos, en herramientas SIEM sofisticadas, en consultores de amenazas avanzadas. Están certificadas ISO 27001. Tienen políticas de seguridad de 200 páginas que nadie lee. Cumplen (o creen cumplir) GDPR.

Pero aquí viene la ironía: el 53% de empresas españolas están **básicamente sin madurez ciberseguridad**. El 51% de las organizaciones globales ya no hace capacitación en concienciación (era 100% en 2008). Los planes de continuidad están documentados pero no se ejecutan paso a paso. Las vulnerabilidades críticas permanecen abiertas 6+ meses. Los incidentes se descubren por terceros, no por el propio SOC.

Es como si tuviéramos un castillo con muros altos pero puertas sin cerradura. Una guardia atenta a la entrada frontal pero dormida a los flancos. Un mapa del territorio enemigo pero sin saber cómo leerlo.

Esta es la realidad que esta encuesta busca capturar. No la realidad ideal (que todos aspiramos a ser), sino la realidad operativa: **lo que realmente hacemos**.

PARTE I: LA IRONÍA COMO BRÚJULA

1.1 La Ironía Constructiva

La ironía en esta encuesta no es sarcasmo. No viene a mofarse de quienes responden "no sabemos" o "no existe". Muy al contrario: la ironía es herramienta diagnóstica.

Cuando una pregunta formula "¿Existe plan continuidad de negocio?", y la respuesta es "L2 (Documentado pero nunca testado)", la ironía es: *"Tenemos un paracaídas sin haber saltado nunca. ¿Confiarías tu vida a él?"*

Esta ironía suave reconoce una verdad incómoda que la mayoría de los líderes conoce pero no articulan públicamente: **la teoría y la práctica de ciberseguridad están desconectadas en la mayoría de organizaciones**.

1.2 Ejemplos de Ironía Narrativa en Preguntas

Módulo A: Governance

Pregunta A.1: Existencia de Política Ciberseguridad

Opciones convencionales: "Sí, No, Parcialmente"

Opción irónica: "Existe algo en un compartida de drive, pero nadie recuerda cuándo se escribió (L1)."

¿Por qué es irónico? Porque captures la realidad de mil organizaciones: la política existe (cumplimiento formal), pero está muerta (nadie la actualiza, nadie la lee, nadie la cita en decisiones).

Módulo B: Risk Management

Pregunta B.7: Gestión de Vulnerabilidades de Terceros

Opción irónica: "Esperamos que los vendors nos lo comuniquen (L0)."

¿Por qué? Porque esperar que un vendor tercero avise de su propia vulnerabilidad es tan ingenuo como esperar que un ladrón llame a la policía. La realidad: si no monitoreamos activamente, nunca nos enteramos.

Módulo E: Training

Pregunta E.3: Phishing Awareness Test

Opción irónica (si score es muy bajo): "Nuestro equipo es cuidadoso" (L0, sin testing).

¿Por qué? Porque es la presunción que justifica la inacción. "Confiamos en nosotros" es lo opuesto al empirismo científico. La realidad: cuando se testea, típicamente 15-25% hace click.

1.3 Función de la Ironía

1.

Revelación: La ironía expone la brecha entre aspiración y realidad.

2.

Empatía: Al ser suave (no sarcástica), no ofende. Permite que el respondente se ría de sí mismo: "Sí, eso somos. Exactamente eso."

3.

Motivación: La ironía bien dosificada genera urgencia: "Si esto es lo que somos, ¿por qué no cambiamos?"

4.

Calibración: La ironía ayuda a evitar auto-engaño. Si te reconoces en la descripción irónica, probable que el nivel sea correcto.

Revelación: La ironía expone la brecha entre aspiración y realidad.

Empatía: Al ser suave (no sarcástica), no ofende. Permite que el respondente se ría de sí mismo: "Sí, eso somos. Exactamente eso."

Motivación: La ironía bien dosificada genera urgencia: "Si esto es lo que somos, ¿por qué no cambiamos?"

Calibración: La ironía ayuda a evitar auto-engaño. Si te reconoces en la descripción irónica, probable que el nivel sea correcto.

PARTE II: LITERALIDAD COMO RIGOR

2.1 ¿Por Qué Lenguaje Literario?

La ciberseguridad es un campo técnico, pero sus stakeholders son humanos. Los humanos comprenden mejor a través de narrativa, no de matrices.

Comparemos:

Versión tecnocrática: "Madurez SIEM: Nivel 2. Cobertura logs: 60-70%. Retención: 90 días. Alertas: <100 reglas. MTTD: 5-7 días."

Versión literaria: "Nuestro SIEM es como un vigilante que duerme 5 días antes de notar que alguien forzó una puerta. Vigila principalmente la entrada frontal, ignorando las ventanas. Y pierde la memoria cada 3 meses."

¿Cuál comunica mejor el riesgo? La segunda. ¿Por qué? Porque crea **imagen mental**.

2.2 Niveles de Madurez como Acto Teatral

En esta encuesta, los niveles L0-L5 no son solo números. Son personajes en una obra:

Acto I: Ignorancia (L0)

- Personaje: La organización que desconoce la realidad.
- Diálogo: "¿Analizamos riesgos? Creemos que somos suficientemente cuidadosos."
- Escena: El "descubrimiento accidental" de una brecha importante.

Acto II: Despertar (L1)

- Personaje: La organización que comienza a reaccionar.
- Diálogo: "Hace poco tuvimos un incidente. Ahora hacemos cosas ad-hoc."
- Escena: Reuniones de crisis, decisiones reactivas.

Acto III: Formación (L2)

- Personaje: La organización que documenta.
- Diálogo: "Tenemos política, procesos, planes. Los revisamos anualmente."
- Escena: Cumplimiento del calendario, pero brecha plan-ejecución.

Acto IV: Operación (L3)

- Personaje: La organización que ejecuta.
- Diálogo: "Lo que escribimos, lo hacemos. Lo que medimos, lo mejoramos."
- Escena: Auditorías que validan, acciones que cierran.

Acto V: Gestión (L4)

- Personaje: La organización que lidera.
- Diálogo: "Basamos decisiones en datos reales. Innovamos continuamente."
- Escena: Métricas vivas, benchmarking externo, investigación interna.

Acto VI: Excelencia (L5)

- Personaje: La organización que es referencia.
- Diálogo: "Somos cantera de talento. Innovamos antes de que sea tendencia."
- Escena: Productos propios, contribución a estándares, influencia en la industria.

2.3 Preguntas como Puertas

Cada pregunta de la encuesta no es solo recopilación de datos. Es una **puerta** que se abre a reflexión más profunda.

Ejemplo: Pregunta C.5 (Remediación de Hallazgos Pentesting)

Pregunta superficial: "¿Cuánto tarda remediar vulnerabilidades críticas?"

Pregunta como puerta (literaria):

"Después de que un pentester descubre que una aplicación crítica tiene falla de autenticación, ¿cuánto tiempo pasa antes de que se implementa la solución? ¿Quién toma la decisión de prioridad? ¿Se bloquea la aplicación o se acepta el riesgo mientras se remedia?"

Esta versión abre preguntas más profundas:

- ¿Existe proceso de priorización de vulnerabilidades?
- ¿Hay conflicto entre seguridad y negocio?
- ¿Se acepta riesgo explícitamente o se ignora?

PARTE III: PROPOSITIVO COMO BRÚJULA DE ACCIÓN

3.1 La Encuesta como Acto Constructivo

Esta encuesta no es **auditoría punitiva**. No hay "ganadores" ni "perdedores". No hay sanciones ocultas ni calificaciones que aparecerán en reportes negativos.

Es, en cambio, **acto de autoconocimiento organizacional**. Como cuando te pesas para saber dónde estás en tu cambio de hábitos, no para juzgarte.

La propuesta de fondo: *"Si respondes con honestidad, descubriremos juntos adónde ir."*

3.2 Estructura Propositiva: Pregunta → Diagnóstico → Acción

Para cada pregunta, la encuesta sigue patrón implícito:

PREGUNTA: ¿Existe análisis formal de riesgos?

↓
DIAGNÓSTICO: L2 (Análisis anual, sin cuantificación FAIR)

↓
ACCIÓN: "Implementar FAIR scorecard para próximos 5 riesgos críticos. Timeline: 90 días. Presupuesto: €15k."

Este patrón asegura que **cada hallazgo lleva a acción**, no solo a dato.

3.3 Propuesta de Valor en Diferentes Niveles

La encuesta propone valor diferenciado según madurez actual:

Si estás en L0-L1:

- Valor: "Descubres que otros están más avanzados; hay camino hacia mejora."
- Propuesta: "Roadmap claro, quick wins en primeros 90 días."

Si estás en L2-L3:

- Valor: "Validas que estás en camino correcto; identificas brechas específicas."
- Propuesta: "Priorización inteligente de inversiones: dónde vale más la pena mejorar."

Si estás en L4-L5:

- Valor: "Benchmarking frente a líderes globales; áreas de innovación."
- Propuesta: "Pasar de mejora incremental a saltos disruptivos."

PARTE IV: TONO LITERARIO-IRÓNICO EN PRÁCTICA

4.1 Modulación del Tono

El tono no es uniforme en toda la encuesta. Varía según:

Módulo A (Governance): Tono de Broma Ejecutiva

Suave, con guiño cómplice a directores.

Razón: Los problemas de governance suelen ser de voluntad política, no de capacidad técnica. La ironía reconoce eso.

Ejemplo:

- "¿CISO en la junta directiva?" → (LO: "Creemos que IT se autogobierna sin supervisión")
- Implícito irónico: *La seguridad sin gobernanza ejecutiva es como Departamento de Marketing sin reportar a CFO.*

Módulo B (Risk Management): Tono de Urgencia Velada

Técnico pero con peso de realidad.

Razón: Los riesgos sin cuantificar son invisibles a líderes empresariales. La ironía expone esa ceguera.

Ejemplo:

- "Riesgo en €: desconocido" → Implícito irónico: *¿Cuánto dinero dejaste en la mesa al no medir riesgo?*

Módulo D (SIEM): Tono de Alarma Dramática

Literario, casi cinematográfico.

Razón: SIEM es la "vista de batalla" de la empresa. Lo que pasa allí determina si se detecta ataque.

Ejemplo:

- "MTTD: 48 horas" — Implícito irónico: *Mientras tu SOC piensa, el atacante ya se fue con los datos.*

Módulo E (Training): Tono de Bemol Triste

Nostálgico, reconociendo la caída del standard.

Razón: Training era 100% en 2008, ahora 51%. Es tragedia silenciosa.

Ejemplo:

- "Training compliance: 48%" — Implícito: *La mitad de tu gente no recibió capacitación. ¿De verdad crees que "no necesitan"?*

4.2 Frases que Capturan el Tono

Ironía

- "Confiamos en que alguien lo haga" (en realidad, nadie lo hace)
- "Nuestro equipo es cuidadoso" (sin evidence)
- "No tenemos presupuesto" (pero sí tenemos para café)
- "Cada departamento hace su copia de seguridad" (caos descentralizado)

Literalidad

- "Nuestro SIEM es como un vigilante dormido"
- "Planes documentados pero no ejecutados: paracaídas sin saltar"
- "Políticas en drive que nadie consulta: ley muerta"
- "Vulnerabilidades que no priorizamos: arsenal que no usamos"

Proposición

- "Si esto es lo que somos, ¿por qué no cambiamos?"
- "90 días para implementar FAIR. €15k. Después, riesgo cuantificado."
- "Roadmap: Q1 quick wins, Q2 baseline, Q3-Q4 advanced. Target 2026: L3."

PARTE V: DIÁLOGO ENTRE CISO Y ENCUESTA

Para ilustrar cómo la encuesta funciona en práctica, imaginemos conversación entre CISO y sí mismo completando la encuesta:

Escena: Oficina del CISO, 15 de enero, 14:30

CISO (leyendo pregunta A.1): "¿Existe una política de ciberseguridad aprobada formalmente por la Dirección?"

Pausa.

CISO (internamente): "Bueno... existe. La escribí hace 3 años. Dirección la firmó. Pero..."

CISO (leeendo opciones):

- L4: "Aprobada, comunicada, con acuerdos de cumplimiento firmados" → No, eso sería ideal.
- L3: "Aprobada, comunicada al 50% de la org" → Más o menos, pero tampoco del todo.
- L2: "Política documentada, pendiente aprobación" → No, sí fue aprobada.

El CISO suena L3, pero la descripción irónica aparece: "Existe, oficial, pero la mayoría de empleados desconoce su existencia."

CISO: "¡Eso es exactamente lo que pasa! Preguntamos a 20 personas aleatorias, y 15 no sabían que existía una política."

Marcar L2 (Documentado)... no. Esperar. Si fue aprobada, es L3.

CISO: "Pero se aprobó hace 3 años. ¿Cuándo fue la última actualización? Ni me acuerdo."

Reconoce: L2. Documentada, pero no comunicada ni actualizada.

CISO (leyendo narrativa en la encuesta): "...porque números sin narrativa son solo ruido. Cada nivel es un acto en una obra."

Sonríe. "Política es como un acto completado hace 3 años, pero el público no está en la sala. Está pasada de moda, además."

CISO: "L2. Final."

Pausa Reflexiva

Eso que acaba de suceder es lo que la encuesta busca lograr: **autoconocimiento sin autoengaño.**

El CISO no salió del ejercicio con vergüenza. Salió con claridad: "Necesito actualizar la política, comunicarla, medir adopción."

PARTE VI: ÉTICA DE LA MEDICIÓN

6.1 La Medición como Acto de Responsabilidad

Medir ciberseguridad tiene implicación ética: **quien mide es responsable de actuar sobre lo medido.**

Si descubres que 51% de empresas no hace training, y luego sigues sin hacer training, la responsabilidad ahora es propia.

Esta encuesta busca **transparencia**: no permite la excusa de "no sabemos dónde estamos". Después de responderla, sabes exactamente dónde estás.

6.2 No-Culpa en la Medición

Parte de la ética es asumir que **L0-L2 no es culpa personal**. A menudo es:

- Falta de presupuesto (decisión empresarial)
- Falta de dirección clara (fallo de liderazgo)
- Complejidad tecnológica (problema técnico)
- Cambio organizacional (contexto)

La encuesta busca identificar **raíz**, no culpable.

6.3 Confidencialidad y Uso de Datos

Implicítamente, esta encuesta asume:

- Los datos son confidenciales (no salen de Dirección)
- Se usan para mejora interna (no para castigo)
- Se comparten con stakeholders que necesitan (CISO, Board, auditores externos si aplica)
- Se anonimizan en reportes de benchmarking

PARTE VII: LA ARQUITECTURA DE LA IRONÍA EN PREGUNTAS

7.1 Estructura de Pregunta Irónica

Una pregunta bien diseñada en esta encuesta tiene estructura:

```
[Descripción neutral]
+
[Opción literaria con narrativa irónica]
+
[Métrica asociada cuantificable]
=
[Puerta a reflexión profunda]
```

7.2 Ejemplo Completo: Pregunta C.5

Descripción Neutral: "¿Cuál es el promedio de tiempo para remediar vulnerabilidades críticas encontradas en pentesting?"

Opciones Irónicas:

- L0: "Reportadas hace 2+ años; aún no remediadas" → Metáfora: deuda técnica eternizada
- L1: "Remediación lenta; promedio 6+ meses" → Metáfora: velocidad de burocracia
- L2: "MTTR 90-180 días para críticas" → Metáfora: aceptable pero no óptimo
- L3: "MTTR 30-90 días para críticas; SLA documentado" → Metáfora: control
- L4: "MTTR <30 días para críticas; algunos remediados en 7 días" → Metáfora: agilidad
- L5: "MTTR <30 días para críticos; algunos remediados en 7 días" → Metáfora: excelencia

Métrica Asociada:

- MTTR crítico (días)

- % de hallazgos críticos remediados en 30 días
- Hallazgos pendientes >90 días

Puerta de Reflexión:

- ¿Por qué tarda tanto remediar críticos?
- ¿Hay conflicto entre seguridad y desarrollo?
- ¿Qué bloquea la remediación? (Presupuesto, prioridad, capacidad técnica)

PARTE VIII: LA PROPUESTA FINAL

8.1 ¿Por Qué Esta Encuesta Funciona?

5.
Honestidad: Reconoce que la realidad es complicada. No simplifica en "sí/no".
6.
Rigor: Exige métrica. No permite vaguedad. "Básicamente seguro" no es respuesta aceptable.
7.
Ironía suave: Permite que el respondente se vea a sí mismo sin defensas, pero sin juzgamiento moralizador.
8.
Literalidad: Crea imagen mental que acompaña la métrica. Hace memorable.
9.
Propositivo: Cada hallazgo llevaindirectamente a acción posible.

Honestidad: Reconoce que la realidad es complicada. No simplifica en "sí/no".

Rigor: Exige métrica. No permite vaguedad. "Básicamente seguro" no es respuesta aceptable.

Ironía suave: Permite que el respondente se vea a sí mismo sin defensas, pero sin juzgamiento moralizador.

Literalidad: Crea imagen mental que acompaña la métrica. Hace memorable.

Propositivo: Cada hallazgo llevaindirectamente a acción posible.

8.2 Cómo Usar Esta Encuesta Éticamente

10. Establece confidencialidad: "Esto es para nosotros, no para auditoría externa."
11. Invita honestidad: "Responde lo que hacemos hoy, no lo que deseamos hacer."
12. Convoca acción: "Después de esta encuesta, discutiremos qué hacer con los resultados."
13. Reconoce contexto: "Algunos gaps son escolares estructurales; algunos son de decisión propia."
14. Celebra fortalezas: "Mira dónde estamos ya, y demuestra que podemos llegar más lejos."

Establece confidencialidad: "Esto es para nosotros, no para auditoría externa."

Invita honestidad: "Responde lo que hacemos hoy, no lo que deseamos hacer."

Convoca acción: "Después de esta encuesta, discutiremos qué hacer con los resultados."

Reconoce contexto: "Algunos gaps son escolares estructurales; algunos son de decisión propia."

Celebra fortalezas: "Mira dónde estamos ya, y demuestra que podemos llegar más lejos."

8.3 Propuesta de Transformación

La encuesta culmina con propuesta implícita:

"Tu organización está entre L2 y L3. Eso significa:

- Aceptas que tienes fortalezas (policies documentadas, pentesting regular, algunas herramientas).
- Reconoces brechas claras (training no medido, FAIR ausente, NIS2 no validado).
- Tienes camino visible (roadmap: Q1 quick wins, Q2 baseline, Q3-Q4 advanced).
- Necesitas inversión y cultura (€247k, 2 años, cambio de mindset).

****¿Lo haces? O seguimos adelante sin medición clara, confiando en que 'alguien se encarga'?"**

CONCLUSIÓN: LA INVITACIÓN

Esta encuesta es **invitación**.

Invitación a mirarse en el espejo sin autoengaño.

Invitación a reconocer que ciberseguridad no es problema que se resuelve con herramientas o consultores externos, sino **con decisión sostenida de mejora continua**.

Invitación a pasar de "confiamos en nosotros" a "medimos, aprendemos, mejoramos."

Invitación a la excelencia, que comienza con la honestidad.

"En la ironía está la verdad. En la verdad está la posibilidad. En la posibilidad está la acción."

—Esta Encuesta

FIN DE LA NARRATIVA EXPLICATIVA